

THREAT ADVISORY



**VULNERABILITY
REPORT**

**Deserialization of untrusted data by
Fastjson library leads to RCE**

Date of Publication

June 17, 2022

Admiralty code

A1

TA Number

TA2022126

Summary

Applications using Fastjson java library are impacted by remote code execution vulnerability.

CVEs

CVE	NAME	PATCH
CVE-2022-25845	Remote Code Execution	

Potential MITRE ATT&CK TTPs

TA0002 Execution	TA0005 Defense Evasion	T1203 Exploitation for Client Execution	T1055 Process Injection
T1211 Exploitation for Defense Evasion			

Technical Details

Fastjson is a library used by applications to convert java objects to json and vice versa. "AutoType" function of this library deserialized untrusted data which allows attacker to inject arbitrary code and perform Remote Code Execution.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	CWE ID
CVE-2022-25845	1.2.80 or earlier version	CWE-502

Patch Details

Update to Fastjson version 1.2.83 or enable SafeMode
Path Links

https://github.com/alibaba/fastjson/wiki/fastjson_safeMode

<https://github.com/alibaba/fastjson/commit/35db4adad70c32089542f23c272def1ad920a60d>

<https://github.com/alibaba/fastjson/commit/8f3410f81cbd437f7c459f8868445d50ad301f15>

<https://github.com/alibaba/fastjson/releases/tag/1.2.83>

References

<https://thehackernews.com/2022/06/high-severity-rce-vulnerability.html>

<https://nvd.nist.gov/vuln/detail/CVE-2022-25845>

<https://jfrog.com/blog/cve-2022-25845-analyzing-the-fastjson-auto-type-bypass-rce-vulnerability/>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

June 17, 2022 • 7:45 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com